

HCL AppScan Report

Report Type: Security Report

Application Name: Smart Tools

Business Impact: Unspecified

Report created at: Thursday, June 4, 2026

This report was generated by HCL AppScan

Summary of security issues

Medium severity issues: 26

Low severity issues: 3

Total security issues: 29

Table of Contents

Summary

- Issues

Fix-Groups

- Common API Call: Configuration:
- Common API Call: PrototypePollution:
- Common API Call: URL Validation Required:
- Common API Call: Open Redirect:
- Common Open Source: Open Source Component:
- Common Open Source: Open Source Component:
- Common Open Source: Open Source Component:
- Common Open Source: Open Source Component:
- Common Open Source: Open Source Component:
- Common Open Source: Open Source Component:
- Common Open Source: Open Source Component:
- Common Fix Point:Configuration:
- Common Fix Point:Cross-Site Scripting:
- Common Fix Point:URL Validation Required:
- Common Fix Point:URL Validation Required:
- Common Fix Point:URL Validation Required:

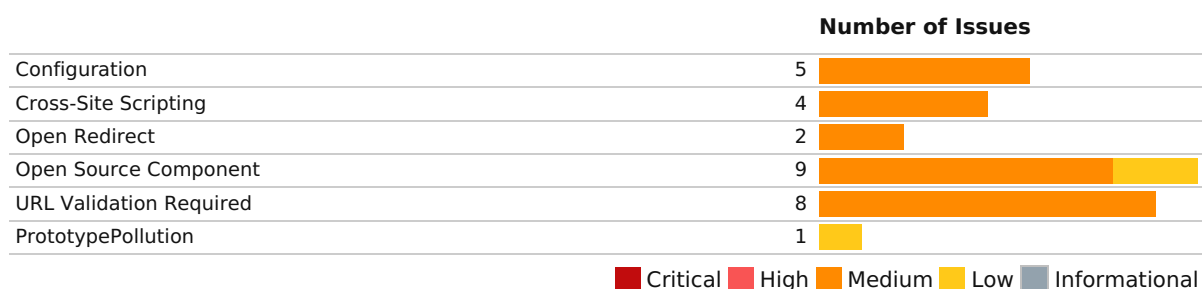
How to Fix

- Configuration
- Configuration - Insecure use of base image version detected in Dockerfile
- Cross-Site Scripting
- Open Redirect
- Open Source Component
- PrototypePollution
- URL Validation Required

Summary

Total security issues: **29**

Issue Types: **6**



Issues - By Fix Groups:

M	Common API Call: Configuration: Insecure use of base image version detected in Dockerfile
Fix Group ID:	3d3d997a-b85d-f111-8fcb-0022484e63bd
Status:	Open
Date:	2026-06-01 12:50:34Z
API:	Insecure use of base image version detected in Dockerfile
How to Fix:	Configuration

Issue 1 of 3

Issue ID:	883d997a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	3d3d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal\Dockerfile:3
Line	3
Source File	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal\Dockerfile
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	16

Issue 1 of 3 - Details

Call

FROM node:18-alpine AS build

Issue 2 of 3

Issue ID:	8b3d997a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	3d3d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal\Dockerfile:12
Line	12
Source File	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal\Dockerfile
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	16

Issue 2 of 3 - Details

Call

FROM nginx:alpine

Issue 3 of 3

Issue ID:	8e3d997a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	3d3d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal\backend-python\Dockefile:5
Line	5
Source File	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal\backend-python\Dockefile
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	16

Issue 3 of 3 - Details

Call

FROM python:3.11-slim

L	Common API Call: PrototypePollution: if (fyMatch) acc[fyMatch[1]] = v;
Fix Group ID:	a28f5b90-da58-f111-8fcb-0022484e63bd
Status:	Open
Date:	2026-05-26 08:12:02Z
API:	if (fyMatch) acc[fyMatch[1]] = v;
How to Fix:	PrototypePollution

Issue 1 of 1

Issue ID:	703d997a-b85d-f111-8fcb-0022484e63bd
Severity:	Low
Status	Open
Fix Group ID:	a28f5b90-da58-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal/src/components/assessment Tabs.jsx:235
Line	235
Source File	Supply Chain Rapid Diagnostics Factory\LLM GenAI Rapid E2E Acc-Internal/src/components/assessment Tabs.jsx
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	1321

Issue 1 of 1 - Details

Trace

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/assessmentTabs.js

x

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/assessmentTabs.jsx:5

1

function getTabConfig({

state = {},

handlers = {},

meta = {},

user,

} = {}) {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/assessmentTabs.jsx:5

8

selectedKPI

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/assessmentTabs.jsx:1

00

peerFinancialData

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/assessmentTabs.jsx:1

80

rawPeerData = peerFinancialData?.data || peerFinancialData || {}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/assessmentTabs.jsx:2

30

block = rawPeerData[blockKey] || {}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/assessmentTabs.jsx:2

31

Object.entries(block)

.filter((k) => /^PeerMedian\s+FY-/i.test(k))

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/assessmentTabs.jsx:2

33

(acc, [k, v]) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/assessmentTabs.jsx:2

34

k.match(/(FY\d{2}\d{4})/i)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/assessmentTabs.jsx:2

34

fyMatch = k.match(/(FY\d{2}\d{4})/i)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/assessmentTabs.jsx:2

35

if (fyMatch) acc[fyMatch[1]] = v;

M	Common API Call: URL Validation Required: navigate(`?tab=\$
Fix Group ID:	433d997a-b85d-f111-8fcb-0022484e63bd
Status:	Open
Date:	2026-06-01 12:50:34Z
API:	navigate(`?tab=\$
How to Fix:	URL Validation Required

Issue 1 of 1

Issue ID:	4f3d997a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	433d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:412
Line	412
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	425

Issue 1 of 1 - Details

Trace

```
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.js
x
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:9
3
(state) => state.tabAccess.unlockedTabs
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:9
3
state.tabAccess.unlockedTabs
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:9
3
(state) => state.tabAccess.unlockedTabs
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:9
3
useSelector((state) => state.tabAccess.unlockedTabs)
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:9
3
unlockedTabs = useSelector((state) => state.tabAccess.unlockedTabs)
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
08
lastUnlocked = unlockedTabs[unlockedTabs.length - 1] || "Templates"
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
11
safeTarget = ALLOWED_TABS.has(lastUnlocked) ? lastUnlocked : "Templates"
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
12
navigate(`?tab=${safeTarget}`, { replace: true })
```

M	Common API Call: Open Redirect: a.href = url
Fix Group ID:	a18f5b90-da58-f111-8fcb-0022484e63bd
Status:	Open
Date:	2026-05-26 08:12:02Z
API:	a.href = url
How to Fix:	Open Redirect

Issue 1 of 2

Issue ID:	4c3d997a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	a18f5b90-da58-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/FileUploadContainer.jsx:100
Line	100
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/FileUploadContainer.jsx
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	601

Issue 1 of 2 - Details

Trace

```
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/FileUploadContainer.js
x
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/FileUploadContainer.js
sx:84
url = URL.createObjectURL(fileObj.file)
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/FileUploadContainer.js
sx:89
URL.revokeObjectURL(url)
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/FileUploadContainer.js
sx:100
a.href = url
```

Issue 2 of 2

Issue ID:	823d997a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	a18f5b90-da58-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:76
Line	76
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	601

Issue 2 of 2 - Details

Trace

```
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js
s
    Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:6
0
    url = window.URL.createObjectURL(blob)

    Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:6
5
    window.URL.revokeObjectURL(url)

    Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:7
6
    a.href = url
```

M	Common Open Source: Open Source Component: serialize-javascript
Fix Group ID:	17c0f92a-b85d-f111-8fcb-0022484e63bd
Status:	Open
Date:	2026-06-01 12:48:06Z
Library name:	serialize-javascript
Library Version:	6.0.2
How to Fix:	Open Source Component See also issue-details 'Resolution' section below.

Issue 1 of 1

Issue ID:	1dc0f92a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	17c0f92a-b85d-f111-8fcb-0022484e63bd
Location	../Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/package.json
Line	0
Source File	../Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/package.json
CVSS	5.9
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CVE	CVE-2026-34043
CWE:	829

Issue 1 of 1 - Details

Name: CVE-2026-34043

Description: Serialize JavaScript has CPU Exhaustion Denial of Service via crafted array-like objects
Resolution: Upgrade package to version greater than or equal to 7.0.5
URL: <https://github.com/advisories/GHSA-qj8w-gfj5-8c6v>
EPSS Score: 0.00018
EPSS Percentile: 0.04923

M	Common Open Source: Open Source Component: postcss		
Fix Group ID:	14c0f92a-b85d-f111-8fcb-0022484e63bd		
Status:	Open		
Date:	2026-06-01 12:48:06Z		
Library name:	postcss		
Library Version:	7.0.39		
How to Fix:	Open Source Component See also issue-details 'Resolution' section below.		

Issue 1 of 2

Issue ID:	1ac0f92a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	14c0f92a-b85d-f111-8fcb-0022484e63bd
Location	../../Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/package.json
Line	0
Source File	../../Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/package.json
CVSS	6.1
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CVE	CVE-2026-41305
CWE:	829

Issue 1 of 2 - Details

Name:	CVE-2026-41305
Description:	PostCSS has XSS via Unescaped </style> in its CSS Stringify Output
Resolution:	Upgrade package to version greater than or equal to 8.5.10
URL:	https://github.com/advisories/GHSA-qx2v-qp2m-jg93
EPSS Score:	0.00029
EPSS Percentile:	0.08281

Issue 2 of 2

Issue ID:	1ec0f92a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	14c0f92a-b85d-f111-8fcb-0022484e63bd
Location	../../Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/package.json
Line	0
Source File	../../Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/package.json
CVSS	5.3
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CVE	CVE-2023-44270
CWE:	829

Issue 2 of 2 - Details

Name:	CVE-2023-44270
Description:	PostCSS line return parsing error
Resolution:	Upgrade package to version greater than or equal to 8.4.31
URL:	https://github.com/advisories/GHSA-7fh5-64p2-3v2j
EPSS Score:	0.00177
EPSS Percentile:	0.39767

M	Common Open Source: Open Source Component: uuid
Fix Group ID:	15c0f92a-b85d-f111-8fcb-0022484e63bd
Status:	Open
Date:	2026-06-01 12:48:06Z
Library name:	uuid
Library Version:	8.3.2
How to Fix:	Open Source Component See also issue-details 'Resolution' section below.

Issue 1 of 1

Issue ID:	1fc0f92a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	15c0f92a-b85d-f111-8fcb-0022484e63bd
Location	../../Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/package.json
Line	0
Source File	../../Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/package.json
CVSS	6.3
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CVE	CVE-2026-41907
CWE:	829

Issue 1 of 1 - Details

Name:	CVE-2026-41907
Description:	uuid: Missing buffer bounds check in v3/v5/v6 when buf is provided
Resolution:	Upgrade package to version greater than or equal to 11.1.1
URL:	https://github.com/advisories/GHSA-w5hq-g745-h8pq
EPSS Score:	0.0004
EPSS Percentile:	0.12049

L	Common Open Source: Open Source Component: @tootallnate/once
Fix Group ID:	0fc0f92a-b85d-f111-8fcb-0022484e63bd
Status:	Open
Date:	2026-06-01 12:48:06Z
Library name:	@tootallnate/once
Library Version:	1.1.2
How to Fix:	Open Source Component See also issue-details 'Resolution' section below.

Issue 1 of 1

Issue ID:	23c0f92a-b85d-f111-8fcb-0022484e63bd
Severity:	Low
Status	Open
Fix Group ID:	0fc0f92a-b85d-f111-8fcb-0022484e63bd
Location	../Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/package.json
Line	0
Source File	../Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/package.json
CVSS	1.9
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CVE	CVE-2026-3449
CWE:	829

Issue 1 of 1 - Details

Name:	CVE-2026-3449
Description:	@tootallnate/once vulnerable to Incorrect Control Flow Scoping
Resolution:	Upgrade package to version greater than or equal to 2.0.1
URL:	https://github.com/advisories/GHSA-vpq2-c234-7xj6
EPSS Score:	0.00018
EPSS Percentile:	0.04687

M	Common Open Source: Open Source Component: eslint
Fix Group ID:	0cc0f92a-b85d-f111-8fcb-0022484e63bd
Status:	Open
Date:	2026-06-01 12:48:06Z
Library name:	eslint
Library Version:	8.57.1
How to Fix:	Open Source Component See also issue-details 'Resolution' section below.

Issue 1 of 1

Issue ID:	1bc0f92a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	0cc0f92a-b85d-f111-8fcb-0022484e63bd
Location	../Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/package.json
Line	0
Source File	../Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/package.json
CVSS	5.5
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CVE	CVE-2025-50537
CWE:	829

Issue 1 of 1 - Details

Name:	CVE-2025-50537
Description:	eslint has a Stack Overflow when serializing objects with circular references
Resolution:	Upgrade package to version greater than or equal to 9.26.0
URL:	https://github.com/advisories/GHSA-p5wg-g6qr-c7cg
EPSS Score:	0.00013
EPSS Percentile:	0.01601

M	Common Open Source: Open Source Component: file-type	
Fix Group ID:	0dc0f92a-b85d-f111-8fcb-0022484e63bd	
Status:	Open	
Date:	2026-06-01 12:48:06Z	
Library name:	file-type	
Library Version:	20.5.0	
How to Fix:	Open Source Component See also issue-details 'Resolution' section below.	

Issue 1 of 2

Issue ID:	24c0f92a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	0dc0f92a-b85d-f111-8fcb-0022484e63bd
Location	../Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/package.json
Line	0
Source File	../Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/package.json
CVSS	5.3
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CVE	CVE-2026-32630
CWE:	829

Issue 1 of 2 - Details

Name: CVE-2026-32630
Description: file-type: ZIP Decompression Bomb DoS via [Content_Types].xml entry
Resolution: Upgrade package to version greater than or equal to 21.3.2
URL: <https://github.com/advisories/GHSA-j47w-4g3g-c36v>
EPSS Score: 0.00039
EPSS Percentile: 0.11475

Issue 2 of 2

Issue ID:	1cc0f92a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	0dc0f92a-b85d-f111-8fcb-0022484e63bd
Location	../Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/package.json
Line	0
Source File	../Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/package.json
CVSS	5.3
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CVE	CVE-2026-31808
CWE:	829

Issue 2 of 2 - Details

Name: CVE-2026-31808
Description: file-type affected by infinite loop in ASF parser on malformed input with zero-size sub-header
Resolution: Upgrade package to version greater than or equal to 21.3.1
URL: <https://github.com/advisories/GHSA-5v7r-6r5c-r473>
EPSS Score:
EPSS Percentile:

L	Common Open Source: Open Source Component: elliptic
Fix Group ID:	13c0f92a-b85d-f111-8fcb-0022484e63bd
Status:	Open
Date:	2026-06-01 12:48:06Z
Library name:	elliptic
Library Version:	6.6.1
How to Fix:	Open Source Component See also issue-details 'Resolution' section below.

Issue 1 of 1

Issue ID:	2ec0f92a-b85d-f111-8fcb-0022484e63bd
Severity:	Low
Status	Open
Fix Group ID:	13c0f92a-b85d-f111-8fcb-0022484e63bd
Location	../../Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/package.json
Line	0
Source File	../../Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/package.json
CVSS	2.9
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CVE	CVE-2025-14505
CWE:	829

Issue 1 of 1 - Details

Name:	CVE-2025-14505
Description:	Elliptic Uses a Cryptographic Primitive with a Risky Implementation
Resolution:	No known patched version is currently available
URL:	https://github.com/advisories/GHSA-848j-6mx2-7j84
EPSS Score:	0.00026
EPSS Percentile:	0.06434

M	Common Fix Point:Configuration: <html lang="en"> <head> <meta charset="utf-8" /> <lin...
Fix Group ID:	403d997a-b85d-f111-8fcb-0022484e63bd
Status:	Open
Date:	2026-06-01 12:50:34Z
Location of fix:	<html lang="en"> <head> <meta charset="utf-8" /> <link rel="icon" href="%PUBLIC_URL%/favicon.ico" /> <meta name="viewport" content="width=device-width, initial-scale=1" /> <meta name="theme-color" content="#000000" /> <meta name="description" content="Web site created using create-react-app" /> <link rel="manifest" href="%PUBLIC_URL%/manifest.json" /> <title>Supply Chain & amp; Operations Benchmarking Tool</title> <link href="https://cdn...
How to Fix:	Configuration

Issue 1 of 2

Issue ID:	463d997a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	403d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/public/index.html:2
Line	2
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/public/index.html
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	16

Issue 1 of 2 - Details

Trace

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/public/index.htm 1
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/public/index.html:2 2 rel="stylesheet"
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/public/index.html:2 1 href="https://fonts.googleapis.com/css2?family=Material+Symbols+Outlined"
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/public/index.html:2 2 <html lang="en"> <head> <meta charset="utf-8" /> <link rel="icon" href="%PUBLIC_URL%/favicon.ico" /> <meta name="viewport" content="width=device-width, initial-scale=1" /> <meta name="theme-color" content="#000000" /> <meta name="description" content="Web site created using create-react-app" /> <link rel="manifest" href="%PUBLIC_URL%/manifest.json" /> <title>Supply Chain & Operations Benchmarking Tool</title> <link href="https://cdn...

Issue 2 of 2

Issue ID:	493d997a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	403d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/public/index.html:2
Line	2
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/public/index.html
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	16

Issue 2 of 2 - Details

Trace

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/public/index.htm

I

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/public/index.html:25

rel="stylesheet"

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/public/index.html:26

href="https://fonts.googleapis.com/css2?family=Material+Symbols+Outlined:opsz,wght,FILL,GRAD@20..48,100..700,0..1,-50..200"

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/public/index.html:2

<html lang="en">

<head>

<meta charset="utf-8" />

<link rel="icon" href="%PUBLIC_URL%/favicon.ico" />

<meta name="viewport" content="width=device-width, initial-scale=1" />

<meta name="theme-color" content="#000000" />

<meta

name="description"

content="Web site created using create-react-app"

/>

<link rel="manifest" href="%PUBLIC_URL%/manifest.json" />

<title>Supply Chain & Operations Benchmarking Tool</title>

<link href="https://cdn...

M	Common Fix Point:Cross-Site Scripting: createApi(
Fix Group ID:	423d997a-b85d-f111-8fcb-0022484e63bd
Status:	Open
Date:	2026-06-01 12:50:34Z
Location of fix:	createApi(
How to Fix:	Cross-Site Scripting

Issue 1 of 4

Issue ID:	763d997a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	423d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:45
Line	45
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	79

Issue 1 of 4 - Details

Trace

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js

s

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:12

2

(headers) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:12

3

headers.set("Authorization", `Bearer \${refreshedToken}`)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:12

2

(headers) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:11

9

fetchBaseQuery({...headers) => {

headers.set("Authorization", `Bearer \${refreshedToken}`);

headers.set("Content-Type", "application/json");

return headers;

};...})

```

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:11
9
retryBaseQuery = fetchBaseQuery({...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:12
8
result = await retryBaseQuery(args, api, extraOptions)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:13
5
return result;

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:8
8
async (args, api, extraOptions) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:8
8
baseQueryWithAuth = async (args, api, extraOptions) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:14
1
createApi({...baseQuery: baseQueryWithAuth...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:15
4
(build) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:17
4
build.query({...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:15
4
{...build.query({
  query: ({ month, channel, productH1, brandH2 } = {}) => {
    const q = new URLSearchParams();
    // CWE-79 fix: safeAppend validates each value before appending
    (Array.isArray(month) ? month : [month]).forEach((val) => {
      if (val && val !== "Overall" && val !== "All") safeAppend(q, "month", val);
    });
    (Array.isArray(channel) ? channel : [channel]).forEach((val) => {
      if (val && val !== "Overall" && val !== "All") safeAppen...

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:17
5
({ month, channel, productH1, brandH2 } = {}) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:17
8
(Array.isArray(month) ? month : {...}).forEach((val) => {...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:17
9
if (val && val !== "Overall" && val !== "All") safeAppend(q, "month", val);

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:4
3
function safeAppend(q, key, rawValue) {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:4
4
safe = sanitiseFilterValue(rawValue)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:3
3
function sanitiseFilterValue(value) {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:3
5
String(value).replace(/[^a-zA-Z0-9 \_\.\/]/g, "")

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:3
5
return String(value).replace(/[^a-zA-Z0-9 \_\.\/]/g, "");

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:3
3
function sanitiseFilterValue(value) {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:4
4
safe = sanitiseFilterValue(rawValue)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:4
5
if (safe) q.append(key, safe);

```

Issue 2 of 4

Issue ID:	793d997a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	423d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:45
Line	45
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	79

Issue 2 of 4 - Details

Trace

```

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js
5
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:10
4
(headers) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:10
8
return headers;

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:10
4
(headers) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:10
1
fetchBaseQuery({...headers) => {
  if (token) {
    headers.set("Authorization", `Bearer ${token}`);
  }
  return headers;
}...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:10
1
baseQuery = fetchBaseQuery({...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:8
8
async (args, api, extraOptions) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:8
8
baseQueryWithAuth = async (args, api, extraOptions) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:14
1
createApi({...baseQuery: baseQueryWithAuth...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:15
4
(build) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:17
4
build.query({...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:15
4
{...build.query({
  query: ({ month, channel, productH1, brandH2 } = {}) => {
    const q = new URLSearchParams();
    // CWE-79 fix: safeAppend validates each value before appending
    (Array.isArray(month) ? month : [month]).forEach((val) => {
      if (val && val !== "Overall" && val !== "All") safeAppend(q, "month", val);
    });
    (Array.isArray(channel) ? channel : [channel]).forEach((val) => {
      if (val && val !== "Overall" && val !== "All") safeAppen...
  });
});

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:17
5
({ month, channel, productH1, brandH2 } = {}) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:17
8
(Array.isArray(month) ? month : {...}).forEach((val) => {...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:17
9
if (val && val !== "Overall" && val !== "All") safeAppend(q, "month", val);

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:4
3
function safeAppend(q, key, rawValue) {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:4
4
safe = sanitiseFilterValue(rawValue)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:3
3
function sanitiseFilterValue(value) {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:3
5
String(value).replace(/[^a-zA-Z0-9 \_\.\-]/g, "")

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:3
5
return String(value).replace(/[^a-zA-Z0-9 \_\.\-]/g, "");

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:3
3
function sanitiseFilterValue(value) {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:4
4
safe = sanitiseFilterValue(rawValue)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:4
5
if (safe) q.append(key, safe);

```

Issue ID:	7c3d997a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	423d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:45
Line	45
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	79

Issue 3 of 4 - Details

Trace

```

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js
s
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:12
2
(headers) => {...}
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:12
5
return headers;
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:12
2
(headers) => {...}
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:11
9
fetchBaseQuery({...headers) => {
  headers.set("Authorization", `Bearer ${refreshedToken}`);
  headers.set("Content-Type", "application/json");
  return headers;
}...})
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:11
9
retryBaseQuery = fetchBaseQuery({...})
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:12
8
result = await retryBaseQuery(args, api, extraOptions)
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:13
5
return result;
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:8
8
async (args, api, extraOptions) => {...}
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:8
8
baseQueryWithAuth = async (args, api, extraOptions) => {...}
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:14
1
createApi({...baseQuery: baseQueryWithAuth...})
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:15
4
(build) => {...}
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:17
4
build.query({...})
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:15
4
{...build.query({
  query: ({ month, channel, productH1, brandH2 } = {}) => {
    const q = new URLSearchParams();
    // CWE-79 fix: safeAppend validates each value before appending
    (Array.isArray(month) ? month : [month]).forEach((val) => {
      if (val && val !== "Overall" && val !== "All") safeAppend(q, "month", val);
    });
    (Array.isArray(channel) ? channel : [channel]).forEach((val) => {
      if (val && val !== "Overall" && val !== "All") safeAppend...
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:17
5
({ month, channel, productH1, brandH2 } = {}) => {...}
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:17
8
(Array.isArray(month) ? month : {...}).forEach((val) => {...})
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:17
9
if (val && val !== "Overall" && val !== "All") safeAppend(q, "month", val);
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:4
3
function safeAppend(q, key, rawValue) {...}

```

```
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:4
4
safe = sanitiseFilterValue(rawValue)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:3
3
function sanitiseFilterValue(value) {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:3
5
String(value).replace(/[^a-zA-Z0-9 \-_.]/g, "")

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:3
5
return String(value).replace(/[^a-zA-Z0-9 \-_.]/g, "");

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:3
3
function sanitiseFilterValue(value) {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:4
4
safe = sanitiseFilterValue(rawValue)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:4
5
if (safe) q.append(key, safe);
```

Issue 4 of 4

Issue ID:	7f3d997a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	423d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:45
Line	45
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	79

Issue 4 of 4 - Details

Trace

```
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js
s

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:12
2
(headers) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:12
4
headers.set("Content-Type", "application/json")

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:12
2
(headers) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:11
9
fetchBaseQuery({...(headers) => {
  headers.set("Authorization", `Bearer ${refreshedToken}`);
  headers.set("Content-Type", "application/json");
  return headers;
}...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:11
9
retryBaseQuery = fetchBaseQuery({...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:12
8
result = await retryBaseQuery(args, api, extraOptions)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:13
5
return result;

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:8
8
async (args, api, extraOptions) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:8
8
baseQueryWithAuth = async (args, api, extraOptions) => {...}
```

```
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:14
1 createApi({...baseQuery: baseQueryWithAuth...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:15
4 (build) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:17
4 build.query({...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:15
4 {...build.query({
  query: ({ month, channel, productH1, brandH2 } = {}) => {
    const q = new URLSearchParams();
    // CWE-79 fix: safeAppend validates each value before appending
    (Array.isArray(month) ? month : [month]).forEach((val) => {
      if (val && val !== "Overall" && val !== "All") safeAppend(q, "month", val);
    });
    (Array.isArray(channel) ? channel : [channel]).forEach((val) => {
      if (val && val !== "Overall" && val !== "All") safeAppen...

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:17
5 ({ month, channel, productH1, brandH2 } = {}) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:17
8 (Array.isArray(month) ? month : [month]).forEach((val) => {...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:17
9 if (val && val !== "Overall" && val !== "All") safeAppend(q, "month", val);

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:4
3 function safeAppend(q, key, rawValue) {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:4
4 safe = sanitiseFilterValue(rawValue)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:3
3 function sanitiseFilterValue(value) {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:3
5 String(value).replace(/[^a-zA-Z0-9 \_\.\/]/g, "")

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:3
5 return String(value).replace(/[^a-zA-Z0-9 \_\.\/]/g, "");

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:3
3 function sanitiseFilterValue(value) {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:4
4 safe = sanitiseFilterValue(rawValue)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/services/kpiApi.js:4
5 if (safe) q.append(key, safe);
```

M	Common Fix Point:URL Validation Required: if (!unlockedTabs.includes(selectedTab))
Fix Group ID:	443d997a-b85d-f111-8fcb-0022484e63bd
Status:	(Mixed)
Date:	2026-06-01 12:50:34Z
Location of fix:	if (!unlockedTabs.includes(selectedTab))
How to Fix:	URL Validation Required

Issue ID:	553d997a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	443d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:588
Line	588
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	425

Issue 1 of 5 - Details

Trace

```

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.js
x
  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:9
  3
  (state) => state.tabAccess.unlockedTabs

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:9
  3
  state.tabAccess.unlockedTabs

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:9
  3
  (state) => state.tabAccess.unlockedTabs

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:9
  3
  useSelector((state) => state.tabAccess.unlockedTabs)

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:9
  3
  unlockedTabs = useSelector((state) => state.tabAccess.unlockedTabs)

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
  07
  unlockedTabs.includes(selectedTab)

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
  07
  if (!unlockedTabs.includes(selectedTab)) {...}

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
  17
  useMemo(() => {...}, [selectedTab...])

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
  17
  columns

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
  99
  getTabConfig({...columns...})

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
  99
  tabConfig = getTabConfig({...})

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:5
  71
  tabContent

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:5
  71
  tabPages

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:5
  78
  tabs = Object.keys(tabPages)

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:5
  82
  nextTab = tabs[nextIndex]

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:5
  83
  if (!unlockedTabs.includes(nextTab)) {...}

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:5
  84
  dispatch(unlockTab(nextTab))

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:5
  87
  safeNext = ALLOWED_TABS.has(nextTab) ? nextTab : "Templates"

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:5
  88
  navigate(`?tab=${safeNext}`)

```

Issue 2 of 5

Issue ID:	583d997a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	443d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:590
Line	590
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	425

Issue 2 of 5 - Details

Trace

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.js

x

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93

(state) => state.tabAccess.unlockedTabs

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93

state.tabAccess.unlockedTabs

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93

(state) => state.tabAccess.unlockedTabs

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93

useSelector((state) => state.tabAccess.unlockedTabs)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93

unlockedTabs = useSelector((state) => state.tabAccess.unlockedTabs)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:407

unlockedTabs.includes(selectedTab)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:407

if (!unlockedTabs.includes(selectedTab)) {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:417

useMemo(() => {...}, [selectedTab...])

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:417

columns

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:499

getTabConfig({...columns...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:499

tabConfig = getTabConfig({...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:571

tabContent

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:571

tabPages

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:578

tabs = Object.keys(tabPages)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:590

navigate(`?tab=\${tabs[currentIndex]}`)

Issue 3 of 5

Issue ID:	613d997a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	443d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:685
Line	685
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	425

Issue 3 of 5 - Details

Trace

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.js x
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93 (state) => state.tabAccess.unlockedTabs
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93 state.tabAccess.unlockedTabs
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93 (state) => state.tabAccess.unlockedTabs
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93 useSelector((state) => state.tabAccess.unlockedTabs)
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93 unlockedTabs = useSelector((state) => state.tabAccess.unlockedTabs)
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:407 unlockedTabs.includes(selectedTab)
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:407 if (!unlockedTabs.includes(selectedTab)) {...}
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:685 navigate(`?tab=\${selectedTab}`)

Issue 4 of 5

Issue ID:	673d997a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	443d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:817
Line	817
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	425

Issue 4 of 5 - Details

Trace

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.js

x

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93

(state) => state.tabAccess.unlockedTabs

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93

state.tabAccess.unlockedTabs

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93

(state) => state.tabAccess.unlockedTabs

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93

useSelector((state) => state.tabAccess.unlockedTabs)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93

unlockedTabs = useSelector((state) => state.tabAccess.unlockedTabs)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:407

unlockedTabs.includes(selectedTab)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:407

if (!unlockedTabs.includes(selectedTab)) {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:417

useMemo(() => {...}, {selectedTab...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:417

columns

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:499

getTabConfig({...columns...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:499

tabConfig = getTabConfig({...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:571

tabContent

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:571

tabPages

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:810

tabs = Object.keys(tabPages)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:814

ALLOWED_TABS.has(tabs[prevIndex])

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:814

safePrev = ALLOWED_TABS.has(tabs[prevIndex])
? tabs[prevIndex]
: "Templates"

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:817

navigate(`?tab=\${safePrev}`)

Issue 5 of 5

Issue ID:	6a3d997a-b85d-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	443d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:900
Line	900
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx
Date Created	Monday, June 1, 2026
Last Updated	Monday, June 1, 2026
CWE:	425

Issue 5 of 5 - Details

Trace

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93

(state) => state.tabAccess.unlockedTabs

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93

state.tabAccess.unlockedTabs

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93

(state) => state.tabAccess.unlockedTabs

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93

useSelector((state) => state.tabAccess.unlockedTabs)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93

unlockedTabs = useSelector((state) => state.tabAccess.unlockedTabs)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:407

unlockedTabs.includes(selectedTab)

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:407

if (!unlockedTabs.includes(selectedTab)) {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:417

useMemo(() => {...}, {selectedTab...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:417

columns

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:499

getTabConfig({...columns...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:499

tabConfig = getTabConfig({...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:571

tabContent

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:571

tabPages

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:884

Object.keys(tabPages).map((tab, idx) => {...})

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:884

(tab, idx) => {...}

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:887

isVisited = visitedTabs.has(tab) && selectedTab !== tab

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:899

safeTab = ALLOWED_TABS.has(tab) ? tab : "Templates"

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:900

navigate(`?tab=\${safeTab}`)

M	Common Fix Point:URL Validation Required: safeRetry = ALLOWED_TABS.has(selectedTab) ? sel...
Fix Group ID:	191217a9-db5f-f111-8fcb-0022484e63bd
Status:	(Mixed)
Date:	2026-06-04 06:07:31Z
Location of fix:	safeRetry = ALLOWED_TABS.has(selectedTab) ? selectedTab : "Templates"
How to Fix:	URL Validation Required

Issue ID:	291217a9-db5f-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	191217a9-db5f-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:696
Line	696
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx
Date Created	Thursday, June 4, 2026
Last Updated	Thursday, June 4, 2026
CWE:	425

Issue 1 of 1 - Details

Trace

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.js x
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93 (state) => state.tabAccess.unlockedTabs
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93 state.tabAccess.unlockedTabs
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93 (state) => state.tabAccess.unlockedTabs
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93 useSelector((state) => state.tabAccess.unlockedTabs)
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:93 unlockedTabs = useSelector((state) => state.tabAccess.unlockedTabs)
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:407 unlockedTabs.includes(selectedTab)
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:407 if (!unlockedTabs.includes(selectedTab)) {...}
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:693 safeRetry = ALLOWED_TABS.has(selectedTab) ? selectedTab : "Templates"
Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:696 navigate(`?tab=\${safeRetry}`)

M	Common Fix Point:URL Validation Required: tabPage
Fix Group ID:	3f3d997a-b85d-f111-8fcb-0022484e63bd
Status:	(Mixed)
Date:	2026-06-01 12:50:34Z
Location of fix:	tabPages
How to Fix:	URL Validation Required

Issue 1 of 1

Issue ID:	231217a9-db5f-f111-8fcb-0022484e63bd
Severity:	Medium
Status	Open
Fix Group ID:	3f3d997a-b85d-f111-8fcb-0022484e63bd
Location	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:595
Line	595
Source File	Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx
Date Created	Thursday, June 4, 2026
Last Updated	Thursday, June 4, 2026
CWE:	425

Issue 1 of 1 - Details

Trace

```

Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.js
x
  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:9
  3
  (state) => state.tabAccess.unlockedTabs

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:9
  3
  state.tabAccess.unlockedTabs

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:9
  3
  (state) => state.tabAccess.unlockedTabs

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:9
  3
  useSelector((state) => state.tabAccess.unlockedTabs)

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:9
  3
  unlockedTabs = useSelector((state) => state.tabAccess.unlockedTabs)

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
  07
  unlockedTabs.includes(selectedTab)

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
  07
  if (!unlockedTabs.includes(selectedTab)) {...}


  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
  17
  useMemo(() => {...}, [selectedTab...])

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
  17
  columns

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
  99
  getTabConfig({...columns...})

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:4
  99
  tabConfig = getTabConfig({...})

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:5
  71
  tabContent

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:5
  71
  tabPages

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:5
  78
  tabs = Object.keys(tabPages)

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:5
  92
  ALLOWED_TABS.has(tabs[currentIndex])

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:5
  92
  safeCurrent = ALLOWED_TABS.has(tabs[currentIndex])
    ? tabs[currentIndex]
    : "Templates"

  Supply Chain Rapid Diagnostics Factory/LLM GenAI Rapid E2E Acc-Internal/src/components/ViewAssessment.jsx:5
  95
  navigate(`?tab=${safeCurrent}`)

```

How to Fix

M Configuration

Cause

A potential security configuration error has been identified. Security configuration errors in the web server, application server, application framework, operating system, or database can threaten the security of the application and its data.

Fix recommendation

Review the identified setting and make sure that all appropriate hardening has been performed. In particular:

- * Verify that default passwords have been replaced with secure passwords.
- * Verify that all unnecessary services and functionality have been disabled.
- * Verify that error handling is configured so that no unwanted information is leaked to the user after an error occurs.

It is recommended that a well-documented and repeatable (or automated) process be adopted to ensure that security hardening is performed consistently and accurately.

CWE

16

External references

- [OWASP Top 10 2010 "A6-Security Misconfiguration"](#)

[Go to Table of Contents](#)

M Configuration - Insecure use of base image version detected in Dockerfile

Cause

Using non-specific versions for base images in Dockerfiles leads to security vulnerabilities by allowing the use of insecure or unstable images. This compromises the security and stability of the container and the host system.

Fix recommendation

Use three-level versioning (major.minor.patch) or SHA256 digests for base images in Dockerfiles.

Avoid using non-specific versions (such latest, alpine, slim, or buster) without specifying a fixed version, as well as single-point (such as, 14), two-point (such as, 14.17), or no versions specified.

External references

- [Docker: Best practices for writing Dockerfiles](#)
- [Docker: Image Digest](#)
- [OWASP Top 10 2010 "A6-Security Misconfiguration"](#)

[Go to Table of Contents](#)

Cause

Cross-site scripting (XSS) vulnerabilities arise when an attacker sends malicious code to the victim's browser, mostly using JavaScript. A vulnerable web application might embed untrusted data in the output, without filtering or encoding it. In this way, an attacker can inject a malicious script to the application, and the script will be returned in the response. This will then run on the victim's browser.

In particular, sanitization of hazardous characters was not performed correctly on user input or untrusted data.

Risk

XSS attacks can expose the user's session cookie, allowing the attacker to hijack the user's session and gain access to the user's account, which could lead to impersonation of users.

An attacker could modify and view the users' records and perform transactions as those users. The attacker may be able to perform privileged operations on behalf of the user, or gain access to any sensitive data belonging to the user. This would be especially dangerous if the user has administrator permissions.

The attacker could even run a malicious script on the victim's browser which would redirect the user to other pages or sites, modify content presentation, or even make it possible to run malicious software or a crypto miner.

Exploit example

The following example shows a script that returns a parameter value in the response. The parameter value is sent to the script using a GET request, and then returned in the response embedded in the HTML.

```
GET /index.aspx?name=JSmith HTTP/1.1
```

```
HTTP/1.1 200 OK
Server: SomeServer
Date: Sun, 01 Jan 2002 00:31:19 GMT
Content-Type: text/html
Accept-Ranges: bytes
Content-Length: 27

<HTML>
Hello JSmith
</HTML>
```

An attacker might leverage the attack like this. In this case, the JavaScript code will be executed by the browser.

```
GET /index.aspx?name=>"><script>alert('XSS')</script> HTTP/1.1
```

```
HTTP/1.1 200 OK
Server: SomeServer
Date: Sun, 01 Jan 2002 00:31:19 GMT
Content-Type: text/html
Accept-Ranges: bytes
Content-Length: 83

<HTML>
Hello >"><script>alert('XSS')</script>
</HTML>
```

Fix recommendation

Fully encode all dynamic data from an untrusted source that is inserted into the webpage, to ensure it is treated as literal text and not as a script that could be executed or markup that could be rendered.

Consider the context in which your data will be used, and contextually encode the data as close as possible to the actual output: e.g. HTML encoding for HTML content; HTML Attribute encoding for data output to attribute values; JavaScript encoding for dynamically generated JavaScript. For example, when HTML encoding non-alphanumeric characters into HTML entities, `<` and `>` would become `<` and `>`.

As an extra defensive measure, validate all external input on the server, regardless of source. Carefully check each input parameter against a rigorous positive specification (allowlist) defining data type; size; range; format; and acceptable values. Regular expressions or framework controls may be useful in some cases, though this is not a replacement for output encoding.

Output encoding and data validation must be done on all untrusted data, wherever it comes from: e.g. form fields, URL parameters, web service arguments, cookies, any data from the network, environment variables, reverse DNS lookups, query results, request headers, URL components, e-mail, files and filenames, databases, and any external systems that provide data to the application. Remember that such inputs may be obtained indirectly through API calls.

For every web page that is returned by the server, explicitly set the `Content-Type` HTTP response header. This header value should define a specific character encoding (charset), such as `ISO-8859-1` or `UTF-8`. When an encoding is not specified, the web browser may choose a different encoding by guessing which encoding is actually being used by the

web page, which would allow a potential attacker to bypass XSS protections.

Additionally, set the `httpOnly` flag on the session cookie, to prevent any XSS exploits from stealing a user's cookie.

Prefer using a framework or standard library that prevents this vulnerability by automatically encoding all dynamic output based on context, or at least that provides constructs that make it easier to avoid.

For every web page that is returned by the server, explicitly set the `Content-Security-Policy` HTTP response header, in order to make it significantly more difficult for the attacker to actually exploit the XSS attack.

CWE

79

External references

- [Cross-site Scripting \(XSS\)](#)
- [OWASP XSS Cheat Sheet](#)

[Go to Table of Contents](#)

M Open Redirect

Cause

The web application redirects users to an external site based on untrusted data. In particular, the submitted request was found to include a URL as a parameter. The web application uses this value to redirect the user's browser to the specified URL.

An attacker can modify this URL value to an arbitrary address. The attacker would then cause the victim to submit the altered request, thus being redirected to a site of the attacker's choosing.

Risk

This vulnerability can allow an attacker to take advantage of the trust the user holds for the application, causing them to trust an arbitrary site under control of the attacker as well. This would often be leveraged through the use of phishing techniques.

Phishing is a social engineering technique where an attacker masquerades as a legitimate entity with which the victim might do business in order to prompt the user to reveal some confidential information (frequently authentication credentials) that can later be used by an attacker. Phishing is essentially a form of information gathering or "fishing" for information.

An attacker may successfully launch a phishing scam and steal user credentials or other sensitive information such as credit card number, social security number, and more.

It can also be possible to redirect the user to install malware that could infect the user's computer.

Exploit example

The following example shows a URL redirection to untrusted site. The `redir` parameter is used to redirect the user to a different page automatically.

```
GET /MyPage.php?redir=/AnotherPage.php HTTP/1.1
```

An attacker might trick the GET parameter used to redirect the user to an external site

```
GET /MyPage.php?redir=https://www.malware.com HTTP/1.1
```

Fix recommendation

Avoid redirecting requests based on untrusted data if possible.

If relying on user input cannot be avoided, the URL should first be validated before redirection. Data that a user can modify must be treated as untrusted data.

A unique token, linked to the current user session, should be sent along with the redirect field value. This unique token should then be verified by the server before the actual redirect takes place. This ensures that attackers would have a harder time using the redirect field to propagate their malicious activities, since they cannot guess the user's session token.

Sanitize input by comparing to a predefined list of trusted URLs, based on an allow-list.

Force all redirects to first go through a page notifying users that they are about to leave your site, with the destination clearly displayed, and have them click a link to confirm.

CWE

601

External references

- [Unvalidated Redirects and Forwards Cheat Sheet](#)

[Go to Table of Contents](#)

M Open Source Component

Cause

A vulnerable version of third party software component is installed in the tested application.

Risk

A vulnerable third party software component may introduce all manner of vulnerabilities into the application

Fix recommendation

Upgrade to the latest version of the third party software component. We highly recommend contacting the vendor of this product to see if a patch or fix has recently been made available.

CWE

829

External references

- [CERT coordination center](#)
- [Common Vulnerabilities and Exposures \(CVE\)](#)

[Go to Table of Contents](#)

L PrototypePollution

Cause

Prototype Pollution occurs when an attacker is able to modify the prototype of a base object (such as `Object.prototype`) in JavaScript, affecting all objects that inherit from it.

This vulnerability typically arises when user input is merged into objects without proper validation, allowing properties like `__proto__`, `constructor`, or `prototype` to be overwritten.

Risk

Prototype Pollution can lead to unexpected application behavior, denial of service, security bypasses, and even remote code execution depending on how polluted objects are used.

It can affect data integrity, application logic, and may allow attackers to escalate privileges or tamper with security controls.

Exploit example

Example Prototype Pollution via Object Merge.
Vulnerable code using `Object.assign`:


```
const obj = {};  
Object.assign(obj, userInput); // userInput = { __proto__: { isAdmin: true } }
```

Result: All objects now inherit isAdmin=true from Object.prototype.

```
if ({}.isAdmin) { /* attacker is admin */ }
```

Fix recommendation

Disallow merging or assigning user input containing __proto__, constructor, or prototype properties.

Use libraries that protect against prototype pollution (e.g., lodash >=4.17.5).

Validate and sanitize all object keys from user input before merging or assignment.

CWE

1321

External references

- [OWASP Prototype Pollution Cheat Sheet](#)
- [CWE-1321: Prototype Pollution](#)
- [Prototype Pollution Explained](#)

[Go to Table of Contents](#)

M URL Validation Required

Cause

This API accepts a URL that is supplied by an outside source. If an attacker is able to manipulate the URL, that attacker could cause legitimate users to fall victim to phishing attacks by redirecting the user to a seemingly legitimate website. If the user thinks that this impostor website is valid, the user may be tricked into submitting login credentials or other type of user information. The impostor website would then send this data to the attacker. Another attack vector would be for an attacker to submit a URL that points to a website that hosts Trojans and other types of malware. If a user is tricked into browsing to this URL, or somehow submitting an HTTP request to this URL, the user's computer may be infected with the Trojans or other malware.

Fix recommendation

It is critical that the URL is validated to point to a legitimate resource. This can be accomplished with a hard coded whitelist of acceptable url paths as well as sanitizing the URL query parameters.

CWE

425